Idaho Technology Authority (ITA)

ENTERPRISE GUIDELINES – G500 SECURITY PROCEDURES

Category: G535 Firewall Configuration Guidelines

CONTENTS:

I. Definitions
II. Rationale
III. Guideline
IV. Procedure Reference
V. Contact Information
Revision History

I. DEFINITIONS

See ITA Guideline G105 (Glossary of Terms) for any definitions. G105 ITA Glossary of Terms

II. RATIONALE

Agencies should deploy firewall mechanisms in the DMZ to control access to the State's network backbone and/or routed infrastructure. Protective controls should at a minimum include the following:

1. Positive source and destination address checking to restrict rogue networks from manipulating the State's routing tables.

2. Authentication to ensure that routing tables do not become corrupted with false entries.

3. Network address translation (NAT) to screen internal network addresses from external view.

4. Firewalls should control inbound and outbound network traffic by limiting that traffic to only that which is necessary to accomplish the mission of the agencies.

III. GUIDELINE

Firewall Configuration and Installation

1. Default-Deny Policy

State of Idaho - Unrestricted/Public

a. Firewalls should enforce a deny-by-default posture: all ports and protocols are closed unless explicitly approved.
b. Only ports and services with documented, business-justified requirements should be opened.
c. Firewall rules should be reviewed at least quarterly to remove obsolete or overly permissive entries (e.g. NIST, CIS).

2. Policy Change Process
    a. Agencies should establish a formal change control process for firewall policy and ruleset modifications.
    b. The process may include:
        i. Security impact analysis prior to implementation.
        ii. Compliance with current NIST SP 800 41 best practices.
        iii. Documentation and approval by designated security authorities.

3. Authorized Administrators
    a. Each agency should designate at least two authorized firewall administrators.
    b. Administrative access should:
        i. Use multi-factor authentication (MFA).
        ii. Be restricted to secure management networks or bastion servers.
        iii. Employ centralized AAA protocols such as TACACS+ or RADIUS for authentication and logging of administrative actions.

4. Port Management
    a. All ports shall be blocked by default; only explicitly approved ports may be opened.
    b. Temporary or emergency port openings:
        i. Should not exceed 72 hours unless extended with documented justification.
        ii. Should trigger automated alerts when nearing expiration.

5. Firewall Stealth
    a. Firewalls should be configured to minimize fingerprinting:
        i. Disable unnecessary services.
        ii. Suppress OS banners and version disclosures.
        iii. Respond minimally to probes.

6. Physical Security
    a. Firewalls shall be installed in physically secure locations approved by the agency Cybersecurity Coordinator.

State of Idaho - Unrestricted/Public

b. Verify that manufacturer-applied tamper-evident seals (e.g., tamper-tape and warranty labels) are intact upon initial receipt. Agencies should inspect these seals and:
    i. Investigate and report any discrepancies immediately to the agency's Cybersecurity Coordinator.
    ii. Refrain from re-sealing

7. Traffic Blocking Requirements
    a. Firewall rulesets should block:
        i. Inbound traffic from non-authenticated sources targeting the firewall itself.
        ii. Inbound traffic with spoofed internal source addresses.
        iii. ICMP traffic inbound to the State Network, except:
            1. ICMP Echo Reply (Type 0) and ICMP Time Exceeded (Type 11) for troubleshooting, limited to designated IPs or subnets.
            2. A perimeter diagnostics host may respond to ICMP Echo Requests for troubleshooting only.
        iv. Inbound traffic containing IP Source Routing information.
        v. Traffic with source or destination address of 0.0.0.0.
        vi. Directed broadcast addresses.
        vii. IPv6 source routing and fragmented packets unless explicitly required.

8. Minimum Firewall Requirements
    a. Local user accounts should exist only for emergency use and remain disabled during normal operations.
    b. Example:
        i. "Local accounts should activate only when centralized AAA (e.g., TACACS+, RADIUS) is unavailable."
    c. Firewalls should:
        i. Use authentication mechanisms that provide individual accountability.
        ii. Store passwords in encrypted form and transmit them over encrypted channels.
        iii. Enforce strong password policies per NIST SP 800 63.

9. Monitoring and Logging
    a. Firewalls should:
        i. Enable logging for all denied and allowed traffic, configuration changes, and administrative access.
        ii. Forward logs to a centralized SIEM, or log collector, for correlation and alerting.

State of Idaho - Unrestricted/Public

iii. Retain logs for at least 90 days online and 1 year offline (or longer if required by law).

b. Agencies handling regulated data (e.g., FTI, CJIS, HIPAA) must comply with applicable federal retention and audit requirements.
c. Firewall policies should be reviewed quarterly for compliance and effectiveness.

IV. PROCEDURE REFERENCE

NIST Framework for Improving Critical Infrastructure Cybersecurity: http://www.nist.gov/cyberframework/upload/cybersecurity-framework-021214.pdf

NIST SP 800-41 (Most current) (Guidelines on Firewalls and Firewall Policy)

Enterprise ITA Policy P4570 (Firewall Security)

Enterprise ITA Policy P4140 (Cybersecurity Framework)

Enterprise ITA Standard S6040 (Firewall Change Request)

V. CONTACT INFORMATION

For more information, contact the ITA Staff at (208) 605-4064.

To report an incident, send email to: cyber@its.idaho.gov or call (208) 605-4000.

REVISION HISTORY

05/05/26 – Updates clarify physical security, streamline traffic-control rules, and refine authentication and logging guidance.

07/23/2025 – Revised for ADA compliance

07/01/18 – Changed “OCIO” to “ITS”.

Effective Date: December 15, 2015

State of Idaho - Unrestricted/Public